

Integer overflow in PyACL #1700

Closed

#1701



joshua-triplett-mandiant opened on May 12, 2021

Contributor ...

Context

When an ACL is resized to add an ACE, it is possible to craft an integer overflow targeting the calculated `required_size`. This results in a smaller than required buffer allocation which causes its `memcpy` of the ACL data to result in a heap overflow.

Expected behavior and actual behavior

- Expected Behavior: Throw an exception indicating that the ACE could not be added because there is not enough room left in the ACL before hitting the size limit.
- Actual Behavior: The `required_size` is overflowed and the `memcpy` results in a heap overflow.

Steps to reproduce the problem

This was reproduced by adding roughly 1800 ACEs to an ACL. The exact count of ACEs that need to be added before reproducing the issue will vary based on the length of the SID in the ACE entry and the current size of the ACL being modified.

Reproduction Goal: Add an ACE to an ACL such that the new size would be larger than `0xFFFF`.

Version of Python and pywin32

Tested on Python 3.5.2 with pywin32 b300

Appears to effect version b157 through b300

CVE

[CVE-2021-32559](#) (Reserved)



joshua-triplett-mandiant added a commit that references this issue on May 12, 2021

PyACL - Fixing integer overflows that occur when resizing ACLs ...

b860822



joshua-triplett-mandiant mentioned this on May 12, 2021

[PyACL - Fixing integer overflows that occur when resizing ACLs #1701](#)



mhammond closed this as completed in [#1701](#) on May 29, 2021



mhammond added a commit that references this issue on May 29, 2021

PyACL - Fixing integer overflows that occur when resizing ACLs ([#1701](#)) ...

Verified 4ad3c5f



mhammond added a commit that references this issue [on Aug 29, 2021](#)

AddAuditAccessAce crashed instead of allocating more memory in some ca. ...

Verified

fbc553f

[Sign up for free](#) to join this conversation on GitHub. Already have an account? [Sign in to comment](#)

Assignees

No one assigned

Labels

No labels

Projects

No projects

Milestone

No milestone

Relationships

None yet

Development



Code with agent mode



 **PyACL - Fixing integer overflows that occur when resizing ACLs**

mhammond/pywin32

Participants

